

Third-Party API Integration Guide

Vetting a New Integration

Before integrating any third-party API, the owning team files an integration request reviewed by both the Security team and the Platform team. Security checks the vendor's data handling terms; Platform checks for an existing internal client before a new one is built from scratch, since duplicate vendor clients are a recurring source of drift.

Credential Management

Third-party API credentials are stored in Vault under the ``integrations/`` path, following the same rules as the Security Guidelines for Handling Secrets. Every third-party credential has an assigned owner and is rotated at minimum every 180 days, or immediately if the vendor reports a breach.

Resilience Requirements

Every call to a third-party API must have a timeout no longer than 5 seconds and must be wrapped in a circuit breaker. A vendor outage must degrade the calling service gracefully, never take it down entirely. Retries use exponential backoff with a maximum of 3 attempts for idempotent calls only; non-idempotent calls are never retried automatically.

Monitoring

Every integration reports latency and error rate to the standard observability dashboard (see the Logging and Observability Standards) tagged by vendor name, so a vendor-side outage is immediately distinguishable from an internal one during an incident.

Deprecation

When a vendor integration is retired, the credential is revoked in Vault within one business day of the last production call, and the integration is removed from the internal service registry so it stops appearing in dependency graphs.